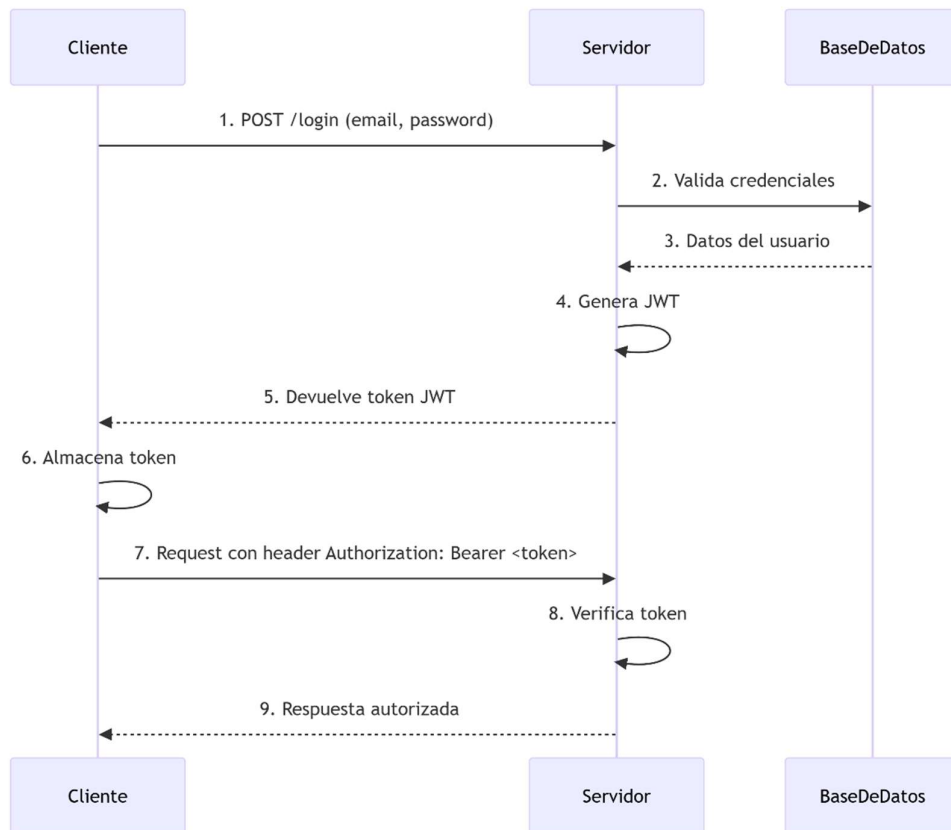




Mecanismo JWT en 4 Pasos

El JWT reemplaza la necesidad de que el servidor "recuerde" si un usuario está conectado a través de una sesión (almacenada en *cookies*). En su lugar, el servidor le da al usuario un **pase de acceso temporal (el JWT)** que el cliente debe mostrar en cada visita.

1. Inicio de Sesión y Generación del Token (Pasos 1 a 5)

Cuando un cliente quiere acceder a su cuenta en el e-commerce:

- **Petición (Paso 1):** El **Cliente** (tu navegador o aplicación móvil) envía un POST `/login` con el *email* y la contraseña al **Servidor**.
- **Validación y Creación (Pasos 2, 3 y 4):** El **Servidor** valida las credenciales contra la **Base de Datos**. Si son correctas, el Servidor **genera un JWT**. Este token contiene información básica del usuario (como su ID de cliente y rol, por ejemplo: `CLIENTE_VIP`) y una **firma criptográfica** para asegurar que nadie pueda modificarlo.
- **Respuesta (Paso 5):** El Servidor devuelve el **JWT** al Cliente.

2. Almacenamiento y Envío (Pasos 6 y 7)

El Cliente ahora tiene su "pase de acceso":

- **Almacenamiento (Paso 6):** El **Cliente** almacena el token (generalmente en la memoria del navegador o en un lugar seguro).

localStorage: Almacena el token de forma persistente. El token permanece incluso después de cerrar la ventana o el navegador.

sessionStorage: Almacena el token solo por la duración de la sesión actual (mientras la pestaña esté abierta).
- **Solicitud de Compra (Paso 7):** El cliente quiere añadir un producto al carrito o ver su historial de pedidos. Envía la solicitud (`/carrito` o `/pedidos`) e incluye siempre el JWT en el *header* **Authorization: Bearer <token>**. Esto prueba su identidad sin enviar la contraseña de nuevo.

3. Verificación y Autorización (Paso 8)

El Servidor no necesita ir a la Base de Datos para verificar:

- **Verificación (Paso 8):** El **Servidor** intercepta la solicitud. Primero, **verifica la firma criptográfica** del JWT. Si la firma es válida, el Servidor sabe que el token fue emitido por él y no ha sido alterado. Luego, lee los datos del token (`CLIENTE_VIP`) para determinar si el usuario tiene permiso para realizar la acción solicitada.

4. Respuesta (Paso 9)

- **Respuesta (Paso 9):** Si el token es válido y el usuario está autorizado, el **Servidor** procesa la solicitud (añade el producto, muestra el historial, etc.) y devuelve la **Respuesta autorizada** al Cliente.